鲜境 FreshMarket 生鲜电商平台

测试报告

Software Test Report

文档编号	FM-STR-001
文档版本	2.0
编制日期	2026-10-18
文档状态	正式稿
适用版本	main @ bb1bde2
密级	内部

本文件依据当前源代码、脚本与 2026-10-18 实际执行结果编制。

目 录

文档控制.....5
1. 概述.....5
1.1 目的.....5
1.2 被测对象.....5
1.3 测试周期.....6
1.4 结论摘要.....6
2. 测试环境.....6
2.1 硬件与操作系统.....6
2.2 软件与依赖版本.....7
2.3 环境隔离说明.....7
3. 测试范围与策略.....7
3.1 测试层级与类型.....7
3.2 准入准则.....8
3.3 准出准则.....8
3.4 不在本轮范围.....8
4. 执行结果汇总.....9
5. 详细测试结果.....10
5.1 静态检查与构建.....10
5.2 API 自动化测试.....10
5.2.1 账号、认证与权限.....11
5.2.2 商品目录、搜索与推荐.....12
5.2.3 购物车、地址与下单.....13
5.2.4 支付、取消、履约与后台订单.....13
5.2.5 售后、评价、结算与事件.....14
5.2.6 失败用例分析.....14
5.2.7 代码覆盖率.....14
5.3 数据库脚本测试.....15
5.4 部署与网关测试.....16

5.5 中间件集成测试.....17
5.6 端到端测试.....18
5.7 运维演练.....23
5.7.1 备份与恢复.....23
5.7.2 回滚.....24
5.8 性能测试.....24
5.9 安全测试.....25
6. 缺陷清单.....26
DEF-01 经营概览在 PostgreSQL 上返回字符串与 NULL.....27
DEF-02 演示/管理员密码被构建进公开前端代码.....27
DEF-03 网关后限流全体用户共享限额.....28
DEF-04 容器化测试镜像缺少 web 源码.....28
DEF-05 运维脚本只有 PowerShell 版本.....28
DEF-06 Compose 项目名写死.....29
DEF-07 生产网关公开 Swagger UI 与 OpenAPI.....29
DEF-08 API 响应安全头重复且冲突.....29
DEF-09 恢复后缓存返回旧数据.....29
DEF-10 转储文件遗留在数据库容器中.....30
DEF-11 外键列缺少索引，迁移无并发锁.....30
DEF-12 开发依赖严重级安全公告.....30
DEF-13 默认镜像标签固定，没有可回滚的旧镜像.....30
DEF-14 告警没有接收端.....30
7. 覆盖率与未覆盖风险.....31
7.1 需求覆盖.....31
7.2 未覆盖风险.....32
8. 结论与发布建议.....32
8.1 准出准则核对.....32
8.2 结论.....32
8.3 发布建议.....33

附录 A 复现命令 33

附录 B 证据文件索引 33

文档控制

项目	内容
文档编号	FM-STR-001
文档名称	鲜境 FreshMarket 系统测试报告
版本	2.0
日期	2026-10-18
状态	正式稿
适用版本	main 分支 commit bb1bde2
编制	FreshMarket 测试组
审核	_____
批准	_____
关联文档	FM-SRS-001《需求规格说明书》、FM-SDD-001《系统设计说明书》

修订记录：

版本	日期	修订人	修订说明
2.0	2026-10-18	FreshMarket 测试组	全面重写：基于 commit bb1bde2 重新执行全部测试，新增数据库脚本、部署、运维演练与安全测试，建立缺陷清单

1. 概述

1.1 目的

本报告记录鲜境 FreshMarket 在 commit bb1bde2 上的系统测试过程、结果与缺陷，评估其是否满足 FM-SRS-001 中的功能与非功能需求，并给出发布建议。本报告的全部结论都来自本轮实际执行的命令及其原始输出。没有执行的项目会明确标注为“未执行”，不引用任何历史结果。

1.2 被测对象

项目	内容
代码仓库	github.com/Weishi-corroding/freshmarket-platform，main 分支
被测提交	bb1bde2（“临时删除各类文档”，其代码与 70ca407 相同）

项目	内容
被测组件	API 服务（Fastify 5）、Web 前端（React 19 + Vite 7）、数据库脚本（database/schema.sql、database/seed.sql、启动迁移与种子逻辑）、部署脚本（compose.yaml、compose.test.yaml、infra/*、scripts/*.ps1、scripts/init-env.sh）
部署形态	本地开发模式（SQLite）与 Docker Compose 完整栈（PostgreSQL + Redis + RabbitMQ + Nginx + Prometheus + Grafana）

1.3 测试周期

测试执行时间为 2026-10-18 19:02—19:31（主机本地时间 UTC−7），即 2026-10-19 02:02—02:31 UTC。所有证据文件中的时间戳均为 UTC。

1.4 结论摘要

- 核心业务功能完整可用。API 自动化测试在 SQLite 上 55/55 通过。端到端测试在本地与 Docker 两种部署下各 9/9 通过。中间件集成冒烟 8/8 通过。备份、恢复、回滚演练全部成功。
- PostgreSQL 上的 API 测试为 54/55，有 1 项失败，原因是缺陷 DEF-01：经营概览接口在 PostgreSQL 上返回字符串与 NULL。GitHub Actions 最近两次提交（70ca407、bb1bde2）的流水线结论均为 failure。
- 共确认缺陷 14 项：高 2 项、中 3 项、低 9 项。预先列出的 4 项“待验证”问题全部被复现确认，没有撤销项。
- 发布建议：当前提交不建议用于本机以外的任何部署。若作为本机隔离的教学演示，可有条件通过。对外发布前必须修复 DEF-01、DEF-02、DEF-03、DEF-04，并重新执行本报告第 4 章的全部测试。

2. 测试环境

2.1 硬件与操作系统

项目	规格
主机	Proxmox 虚拟化环境中的 Linux 实例，3 vCPU，8 GiB 内存
操作系统	Ubuntu 24.04.5 LTS，内核 Linux 6.17.13-2-pve
容器运行时	Docker Engine 29.9.0，Docker Compose v5.6.0

2.2 软件与依赖版本

类别	组件	版本
运行时	Node.js（宿主机测试与 API 镜像）	v24.22.0（npm 11.19.1）
运行时	Node 内置 SQLite	3.53.4
运行时	PowerShell（运维脚本）	7.6.7（官方发布包，sha256 校验通过）
运行时	Python sqlite3（SQL 脚本校验）	3.45.1
数据库	PostgreSQL	17.11（postgres:17-alpine）
缓存	Redis	7.4.11（redis:7.4-alpine）
消息队列	RabbitMQ	4.3.6（rabbitmq:4.3.6-management-alpine）
网关	Nginx	1.28.3（nginx:1.28-alpine）
监控	Prometheus / Grafana	3.13.4 / 13.2.3
框架	fastify / react / vite / typescript	5.12.5 / 19.3.0 / 7.3.7 / 5.9.3
驱动	pg / redis / amqplib	8.23.1 / 5.12.1 / 0.10.9
浏览器测试	Playwright / 浏览器	1.63.0，官方镜像 mcr.microsoft.com/playwright:v1.63.0-noble，Chromium 构建 1243（Chrome for Testing 153.0.8010.12）

2.3 环境隔离说明

- 完整栈从 git archive HEAD 导出的干净副本（/tmp/fmcheck-stack）启动，未使用开发者工作区的未提交文件。密钥由 scripts/init-env.sh 生成。宿主机 8080 端口已被无关进程占用，因此仅通过 compose.override.yaml 把 web 端口改映射为 127.0.0.1:18080，其余配置与仓库一致。
- PostgreSQL API 测试使用独立的一次性容器（PostgreSQL 17.11），每个用例在临时 schema 中执行。结束后检查确认临时 schema 残留为 0。
- 本地 E2E 的 SQLite 数据库放在 /tmp/fmcheck-e2e，不污染开发者的 api/.runtime。
- 测试结束后，所有测试容器、网络、数据卷及临时镜像标签均已清理（见 teardown.txt）。

3. 测试范围与策略

3.1 测试层级与类型

层级/类型	内容	工具
静态检查	TypeScript 严格类型检查（api、web）	tsc

层级/类型	内容	工具
构建验证	API 编译、前端生产构建、Docker 镜像构建	tsc、vite、docker compose build
接口与集成测试	55 个 API 用例，覆盖账号、目录、搜索、购物车、订单、支付、售后、评价、结算、Outbox、权限	node:test + Fastify inject
数据库兼容性测试	同一用例集分别运行于 SQLite 与 PostgreSQL	TEST_DATABASE_URL
数据库脚本测试	DDL/种子脚本可执行性、幂等性、种子一致性、旧版本升级迁移	psql、sqlite3、专用校验脚本
部署测试	Compose 配置、启动顺序、健康检查、端口暴露、网关路由、安全响应头、非 root 运行	docker、curl
中间件集成测试	真实 Redis、RabbitMQ、PostgreSQL 链路冒烟	scripts/infra-smoke.mjs
端到端测试	桌面/手机商城、下单至结算闭环、售后、权限界面、交互缺陷回归	Playwright
运维演练	备份、恢复、回滚（正向与反向用例）	scripts/backup.ps1、restore.ps1、rollback.ps1
性能测试	商品列表接口短时并发测量	scripts/load-test.mjs
安全测试	生产配置守卫、限流有效性、凭据暴露、文档接口暴露、依赖漏洞审计	curl、docker、npm audit

3.2 准入准则

- 被测提交已固定为 bb1bde2，依赖由 package-lock.json 通过 npm ci 安装。
- 测试环境组件版本已记录（见 2.2 节），完整栈各服务健康检查通过。

3.3 准出准则

- 所有自动化用例在两种数据库上全部通过。
- 不存在未关闭的“高”级缺陷。
- 部署与运维演练全部成功，恢复后数据与备份时点一致。
- 生产依赖无已知高危或严重漏洞。

本轮的前两项准出准则未满足（见第 8 章）。

3.4 不在本轮范围

- 真实支付渠道、真实物流对接（系统内为沙箱实现）。
- 长时间稳定性、峰值容量与多节点高可用测试，跨机房容灾与 RPO/RTO 的正式认证。
- 渗透测试、镜像操作系统层漏洞扫描、第三方代码审计。

- Firefox、WebKit 与真机移动设备的兼容性测试（本轮只用 Chromium，手机场景由 390×844 视口模拟）。
- Windows 环境下的脚本执行（PowerShell 脚本在 Linux 上的 PowerShell 7.6.7 中执行）。

4. 执行结果汇总

编号	测试项	执行环境	结果	证据文件
R01	类型检查（api + web）	宿主机 Node 24.22.0	通过	typecheck.txt
R02	生产构建（api + web）	宿主机	通过，前端 JS 369.81 kB（gzip 115.43 kB）	build.txt
R03	API 自动化测试 · SQLite	内存 SQLite	55/55 通过，用时 7.97 s	api-tests-sqlite.txt
R04	API 自动化测试 · PostgreSQL	PostgreSQL 17.11	54/55，1 项失败（DEF-01），用时 16.79 s	api-tests-postgres.txt
R05	容器化测试（compose.test.yaml）	Docker	51/53，2 项失败（DEF-04、DEF-01）	def04-compose-test-run.txt
R06	SQL 脚本加载与幂等	PostgreSQL 17.11、SQLite 3.45.1	通过	db-schema-seed-load.txt
R07	种子数据一致性（seed.sql 与 seed.ts）	Node 24	通过，48 个商品、6 个分类完全一致	db-upgrade-seed-checks.txt
R08	旧版本库升级迁移	SQLite、PostgreSQL	通过，二次迁移幂等	db-upgrade-seed-checks.txt
R09	Compose 配置校验与构建启动	Docker	通过，101 s 内全部健康	docker-compose-up.log
R10	网关、端口、响应头检查	Docker	通过，含 2 项低级缺陷（DEF-07、DEF-08）	docker-gateway-checks.txt
R11	中间件集成冒烟	Docker 内 API 容器	8/8 通过	infra-smoke.json
R12	监控与消息拓扑	Docker	通过，未配置告警接收端（DEF-14）	monitoring-and-mq-checks.txt
R13	端到端测试 · 本地 SQLite	Playwright 1.63.0	9/9 通过，用时 28.5 s	e2e-local-list.txt、e2e-local-results.json
R14	端到端测试 · Docker 完整栈	Playwright 1.63.0	9/9 通过，用时 12.6 s	e2e-docker-list.txt、e2e-docker-results.json
R15	备份与恢复演练	PowerShell 7.6.7	通过，恢复至服务健康共 2.85 s；发现 DEF-09、DEF-10	ops-backup-restore-drill.txt

编号	测试项	执行环境	结果	证据文件
R16	回滚演练（正向与反向）	PowerShell 7.6.7	通过，用时 11.99 s；发现 DEF-13	ops-rollback-drill.txt
R17	性能测试 · 本地 SQLite	200 次请求，并发 10	p95 17.55 ms，错误 0	load-local-sqlite.json
R18	性能测试 · Docker 网关	200 次请求，并发 10	p95 37.58 ms，错误 0；立即重复一次时 100 次返回 429（DEF-03）	load-docker-gateway*.json
R19	生产配置守卫	API 镜像	3/3 弱配置均被拒绝启动	prod-config-validation.txt
R20	限流隔离性	Docker	不通过（DEF-03）	def03-rate-limit-shared-bucket.txt
R21	凭据暴露检查	Docker	不通过（DEF-02）	docker-demo-password-exposure.txt
R22	依赖漏洞审计	npm audit（bb1bde2 锁文件）	生产依赖 0；开发依赖 2 项严重（DEF-12）	npm-audit-prod.json、npm-audit-full.json
R23	远端 CI 状态	GitHub Actions 公共 API	最近 2 次运行 failure，此前 8 次 success	github-actions-runs.json

证据文件均位于 docs/evidence/2026-10-18/。

5. 详细测试结果

5.1 静态检查与构建

- npm run typecheck 对 api 与 web 两个工作区执行严格类型检查，退出码 0，无错误。
- npm run build 退出码 0。前端产物：index.html 0.57 kB；CSS 50.04 kB（gzip 11.04 kB）；JS 369.81 kB（gzip 115.43 kB）；构建用时 2.67 s。没有出现体积超限警告。
- Docker 镜像构建成功：freshmarket-api 369 MB，freshmarket-web 108 MB。API 镜像以 uid 1000（node）运行。

5.2 API 自动化测试

执行命令为 npm test（SQLite）及 TEST_DATABASE_URL=postgres://... npm test（PostgreSQL）。用例位于 api/test/system.test.ts 与 api/test/search-highlight.test.ts，共 55 个。“通过”与“失败”均取自测试运行器的原始输出。

5.2.1 账号、认证与权限

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-04	密码使用随机盐 scrypt 哈希并可校验	FR-ACC、NFR-SEC	通过	通过
TC-API-05	登录、JWT 身份与错误凭据	FR-ACC	通过	通过
TC-API-06	注册拒绝角色注入，只创建会员	FR-ACC、NFR-SEC	通过	通过
TC-API-07	RBAC 拒绝匿名、会员及越岗员工	FR-ADM-USR、NFR-SEC	通过	通过
TC-API-08	会员与员工登录签发不同身份，并拒绝对方入口	FR-ACC、FR-ADM-USR	通过	通过
TC-API-09	员工即使存在历史购物车/订单也无法购物	FR-ACC、FR-ORD	通过	通过
TC-API-10	账号列表与员工开通保持会员/员工分离	FR-ADM-USR	通过	通过
TC-API-11	旧令牌与过期账号类型无法跨越会员/员工边界	FR-ACC、NFR-SEC	通过	通过
TC-API-12	管理员对两类账号的新增、查询、详情、编辑、删除	FR-ADM-USR	通过	通过
TC-API-13	账号增删改查的角色、类型边界、校验与自我保护	FR-ADM-USR	通过	通过
TC-API-14	重置密码、停用/启用、删除使两类入口的旧会话失效	FR-ADM-USR、NFR-SEC	通过	通过
TC-API-15	并发降级管理员时至少保留一名启用的管理员	FR-ADM-USR、NFR-REL	通过	通过
TC-API-16	删除会员时阻止未完成业务并保留已完成订单历史	FR-ADM-USR	通过	通过
TC-API-51	角色撤销对已签发 JWT 立即生效	NFR-SEC	通过	通过
TC-API-55	登录限流阻断暴力尝试并返回统一错误	NFR-SEC	通过	通过

5.2.2 商品目录、搜索与推荐

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-01	搜索高亮实际共有的字符且不改写商品文本	FR-CAT	通过	通过
TC-API-02	Unicode 与大小写归一化下保留原始字形	FR-CAT	通过	通过
TC-API-03	高亮关键词按字面处理正则与 HTML 字符	FR-CAT、NFR-SEC	通过	通过
TC-API-17	仅管理员可删除商品，历史、退款与种子墓碑保留	FR-ADM-PRD	通过	通过
TC-API-18	商品管理支持新增、详情、编辑与上下架筛选	FR-ADM-PRD	通过	通过
TC-API-21	目录校验排序枚举、限制分页并参数化搜索	FR-CAT、NFR-SEC	通过	通过
TC-API-22	种子补充不改变已有库存、账号与订单	FR-CAT、NFR-DEP	通过	通过
TC-API-23	搜索容忍名称单处错字且要求命中全部关键词	FR-CAT	通过	通过
TC-API-24	搜索拒绝重合不足的结果与 SQL 通配符	FR-CAT	通过	通过
TC-API-25	两字搜索对任意商品名使用同一重合算法	FR-CAT	通过	通过
TC-API-26	弱重合结果在分页前截断，准确匹配不受限	FR-CAT	通过	通过
TC-API-27	搜索相关度优先于推荐，显式价格/销量排序仍生效	FR-CAT	通过	通过
TC-API-28	搜索在分页前过滤并排序全部匹配	FR-CAT	通过	通过
TC-API-29	模糊搜索遵守分类与上下架条件，后台同样可用	FR-CAT、FR-ADM-PRD	通过	通过
TC-API-30	默认排序按加权综合推荐而非上架时间	FR-CAT	通过	通过

5.2.3 购物车、地址与下单

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-31	购物车维护数量并拒绝超出库存	FR-CART	通过	通过
TC-API-32	下单快照价格与地址、计算运费并预扣库存	FR-ORD	通过	通过
TC-API-33	满 99 元免配送费	FR-ORD	通过	通过
TC-API-34	同一幂等键 8 次并发重试只创建 1 单	FR-ORD、NFR-REL	通过	通过
TC-API-35	幂等键不能用于不同请求内容	FR-ORD、NFR-REL	通过	通过
TC-API-36	多商品下单失败时全部回滚并保留购物车	FR-ORD、NFR-REL	通过	通过
TC-API-37	两名会员争抢最后 3 件不超卖	FR-ORD、NFR-REL	通过	通过
TC-API-53	地址校验、归属与默认地址选择	FR-ADDR	通过	通过

5.2.4 支付、取消、履约与后台订单

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-38	重复沙箱支付不重复记账、不虚增销量	FR-ORD、NFR-REL	通过	通过
TC-API-39	支付与取消竞争只有一个转换生效	FR-ORD、NFR-REL	通过	通过
TC-API-40	取消幂等，库存只归还一次	FR-ORD	通过	通过
TC-API-41	超时拒绝支付，后台任务只归还一次库存	FR-ORD	通过	通过
TC-API-42	会员不能读取、支付、取消或退款他人订单	FR-ORD、NFR-SEC	通过	通过
TC-API-43	履约遵循严格状态机，确认收货校验归属	FR-ADM-ORD、FR-ORD	通过	通过
TC-API-19	管理员修改配送信息，仅能取消/删除未付款已取消订单	FR-ADM-ORD、FR-ADM-DASH	通过	失败（DEF-01）
TC-API-20	已付款、已履约与财务记录不能删除或绕过流程	FR-ADM-ORD	通过	通过

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-52	库存调整不能为负并产生审计记录	FR-ADM-STK、FR-ADM-AUD	通过	通过
TC-API-54	经营概览、OpenAPI、健康、指标与员工订单脱敏	FR-ADM-DASH、FR-OPS、NFR-PRIV	通过	通过

5.2.5 售后、评价、结算与事件

编号	用例	关联需求	SQLite	PostgreSQL
TC-API-44	待审核售后冻结履约，同意后未发货商品只回库存一次	FR-AFS、FR-ADM-AFS	通过	通过
TC-API-45	已配送生鲜退款后不回库存	FR-AFS	通过	通过
TC-API-46	部分退款只归还所选商品库存，订单保持有效	FR-AFS	通过	通过
TC-API-47	部分退款金额有上限，结算按净额	FR-AFS、FR-ADM-SET	通过	通过
TC-API-48	评价要求已收货商品并禁止重复评价	FR-REV	通过	通过
TC-API-49	结算排除待审核售后且不重复结算	FR-ADM-SET	通过	通过
TC-API-50	事务 Outbox 失败重试并对通知去重	FR-NTF、NFR-REL	通过	通过

5.2.6 失败用例分析

TC-API-19 在 PostgreSQL 上失败于 system.test.ts:263。断言期望经营概览的订单数为数值 0，实际得到字符串 '0'。原因是 GET /api/admin/dashboard（api/src/modules/admin/controller.ts:20）把 COUNT(*)、SUM(...) 的查询结果直接展开到响应中：PostgreSQL 驱动把 bigint/numeric 返回为字符串，pending_fulfillment 在没有订单时为 NULL。SQLite 返回数值，所以同一用例在 SQLite 上通过。这是产品代码在两种数据库下接口契约不一致，不是测试本身的缺陷，记为 DEF-01。

5.2.7 代码覆盖率

文件	SQLite 行/分支/函数 %	PostgreSQL 行/分支/函数 %
app.ts	95.00 / 73.21 / 100.00	95.00 / 73.21 / 100.00
core/database.ts	70.00 / 88.00 / 73.91	63.75 / 94.12 / 47.62
core/runtime.ts	61.63 / 45.95 / 63.16	61.63 / 45.95 / 63.16
core/security.ts	100.00 / 72.73 / 100.00	100.00 / 72.73 / 100.00

文件	SQLite 行/分支/函数 %	PostgreSQL 行/分支/函数 %
modules/accounts/service.ts	97.83 / 86.67 / 100.00	97.83 / 86.52 / 100.00
modules/admin/controller.ts	100.00 / 92.65 / 100.00	100.00 / 92.65 / 100.00
modules/catalog/search.ts	100.00 / 96.30 / 100.00	100.00 / 96.30 / 100.00
modules/catalog/service.ts	100.00 / 86.89 / 100.00	100.00 / 86.89 / 100.00
modules/orders/service.ts	100.00 / 95.50 / 100.00	100.00 / 95.50 / 100.00
modules/orders/repository.ts	100.00 / 93.75 / 100.00	100.00 / 100.00 / 100.00
web/src/search-highlight.ts	100.00 / 100.00 / 100.00	100.00 / 100.00 / 100.00
全部文件	93.83 / 86.93 / 92.27	93.35 / 87.24 / 89.91

两种数据库下 core/database.ts 的覆盖率互补：SQLite 运行覆盖 SQLite 适配分支，PostgreSQL 运行覆盖连接池与事务分支。core/runtime.ts 中的 Redis 连接、RabbitMQ 连接与消费分支在单元测试中不执行，改由 5.5 节的中间件冒烟覆盖。

5.3 数据库脚本测试

编号	测试点	方法	结果
TC-DB-01	schema.sql 在 PostgreSQL 上可执行	psql -v ON_ERROR_STOP=1 导入空库	通过，生成 16 张表、29 个索引（含主键与唯一约束索引）
TC-DB-02	seed.sql 在 PostgreSQL 上可执行且可重复执行	连续导入两次	通过，两次后仍为 6 个分类、48 个商品、6 个账号、1 个地址
TC-DB-03	schema.sql 与 seed.sql 在 SQLite 上可执行且可重复执行	sqlite3（3.45.1，外键开启）导入两次	通过，计数同上
TC-DB-04	种子分类分布	按分类统计	通过，6 个分类各 8 款
TC-DB-05	seed.sql 与应用种子 seed.ts 一致	逐字段比对分类、名称、副标题、价格、原价、库存、图片、规格、产地、储存、标签、浏览量	通过，48 个商品与 6 个分类无差异
TC-DB-06	种子图片存在	检查 web/public/images	通过，引用的图片全部存在
TC-DB-07	旧版本库升级	用首个发布版本（06ceed2）的 schema 建库并写入旧数据，再执行当前 migrate() 与 seed()	通过（SQLite、PostgreSQL）：补齐 active、session_version、views、deleted_at 等列及 refund_items 表；旧商品库存 3 与下架状态被保留；补充 47 款缺失商品；已有账号时不再创建演示员工
TC-DB-08	迁移幂等	对已升级库再次执行 migrate()	通过，无错误

编号	测试点	方法	结果
TC-DB-09	逻辑删除后用户名复用	删除会员后用同名注册、新建员工	返回 409 USERNAME_EXISTS，已删除用户名永久保留。属于设计取舍，不计缺陷
TC-DB-10	外键列索引	查询 pg_constraint 与 pg_index	18 个外键列中有 9 个没有前导索引（DEF-11）
TC-DB-11	测试 schema 清理	测试后查询 information_schema.schemata	本地与容器化测试后 test_% schema 残留均为 0

没有前导索引的外键列为：addresses.user_id、cart_items.product_id、notifications.user_id、order_items.product_id、refund_items.product_id、refunds.user_id、reviews.product_id、reviews.user_id、settlements.operator_id。

5.4 部署与网关测试

编号	测试点	结果
TC-DEP-01	docker compose --env-file .env.docker config --quiet	通过
TC-DEP-02	init-env.sh 生成密钥文件	通过，文件权限 0600，包含 8 项配置；文件已存在时拒绝覆盖（脚本逻辑）
TC-DEP-03	up -d --build 构建并启动 7 个服务	通过，退出码 0，用时 101 s
TC-DEP-04	启动顺序与健康检查	通过：postgres、redis、rabbitmq 健康后 api 启动，api 健康后 web 启动；prometheus、grafana 没有健康检查
TC-DEP-05	网关健康 /healthz	200
TC-DEP-06	/api/health	200，database=postgres、cache=connected、queue=connected
TC-DEP-07	/api/metrics 经网关	404，已阻断外部访问
TC-DEP-08	SPA 深链接 /admin/orders	200，回落 index.html
TC-DEP-09	端口暴露	只发布 127.0.0.1 上的 web（18080）、grafana（3000）、prometheus（9090）与 RabbitMQ 管理端（15672）；postgres、redis、api 不对宿主机发布
TC-DEP-10	运行用户	API 容器 uid=1000(node)，非 root
TC-DEP-11	静态页面安全响应头	通过：nosniff、Referrer-Policy、X-Frame-Options DENY、CSP

编号	测试点	结果
TC-DEP-12	API 响应安全头	不通过：helmet 与 Nginx 各自添加一套，出现两条 CSP、X-Frame-Options 同时为 SAMEORIGIN 与 DENY、Referrer-Policy 两个不同取值，并在明文 HTTP 下发送 HSTS（DEF-08）
TC-DEP-13	接口文档暴露	/api/docs/ 与 /api/openapi.json 经生产网关返回 200（DEF-07）
TC-DEP-14	容器化测试入口 compose.test.yaml	不通过：51/53，search-highlight.test.ts 因镜像缺少 web/src 报 ERR_MODULE_NOT_FOUND（DEF-04），另 1 项为 DEF-01
TC-DEP-15	Compose 项目名	compose.yaml 固定 name: freshmarket，本轮测试栈也只能使用该名称及同名数据卷（DEF-06）

5.5 中间件集成测试

将 scripts/infra-smoke.mjs 复制到 API 容器并执行。脚本使用独立的 PostgreSQL schema、Redis 前缀与 RabbitMQ 命名空间，结束后自行清理。结果为 8/8 通过：

序号	检查点	结果
1	Redis 连接与带认证的 RabbitMQ 连接	通过
2	商品目录缓存写入 Redis 并带 TTL	通过
3	共享 Redis 版本号失效后返回更新后的库存	通过
4	PostgreSQL 事务下单	通过
5	RabbitMQ 发布确认后 Outbox 标记为 sent	通过
6	消费者在提交通知后才确认消息	通过
7	重复投递同一事件只产生一条通知	通过
8	取消订单归还库存，并经持久化队列投递事件	通过

监控与消息拓扑检查结果：

- Prometheus：采集目标 freshmarket-api（http://api:3001/api/metrics）状态 up，up 指标为 1。3 条告警规则（FreshmarketApiDown、FreshmarketHighErrorRate、FreshmarketSlowRequests）均已加载且健康。activeAlertmanagers 为空，即告警不会发送到任何接收端（DEF-14）。

- Grafana 13.2.3：数据库状态 ok。数据源 Prometheus（uid fresh-prometheus）健康检查成功。“FreshMarket · 业务服务监控”仪表盘已自动装载。匿名访问返回 401。
- RabbitMQ：持久化队列 fresh.notifications（1 个消费者，死信交换机 fresh.dead）与 fresh.dead 存在。交换机 fresh.events（topic）与 fresh.dead（fanout）均为持久化。

5.6 端到端测试

用例位于 e2e/shopping.spec.ts，使用官方 Playwright 1.63.0 镜像，单 worker 顺序执行。本地模式连接 SQLite 开发服务（http://127.0.0.1:5173）；Docker 模式连接完整栈网关（http://127.0.0.1:18080），演示密码取自 .env.docker。

编号	场景	关联需求	本地 SQLite	Docker 完整栈
TC-E2E-01	桌面商城：商品图片、搜索与商品详情	FR-CAT	通过	通过
TC-E2E-02	顶部导航高亮与图标分类栏同步	FR-CAT	通过	通过
TC-E2E-03	手机视口控件可用且无横向溢出	NFR-CMP	通过	通过
TC-E2E-04	会员下单、支付、员工履约、确认收货、评价与结算	FR-ORD、FR-REV、FR-ADM-ORD、FR-ADM-SET	通过	通过
TC-E2E-05	顾客售后与客服审核，工作台可见审计	FR-AFS、FR-ADM-AFS、FR-ADM-AUD	通过	通过
TC-E2E-06	仓库岗位可见履约与库存，隐藏特权菜单	FR-ADM-STK、NFR-SEC	通过	通过
TC-E2E-07	顶部配送地址选择器切换区域并同步标签	FR-ADDR	通过	通过
TC-E2E-08	配送时段只为选中项显示勾选标识	FR-ORD	通过	通过
TC-E2E-09	弹窗输入框可正常输入，部分退款可提交	FR-AFS	通过	通过
合计	—	—	9/9，28.5 s	9/9，12.6 s

以下截图来自 Docker 完整栈运行，同名本地截图位于 screenshots/2026-10-18/local/。

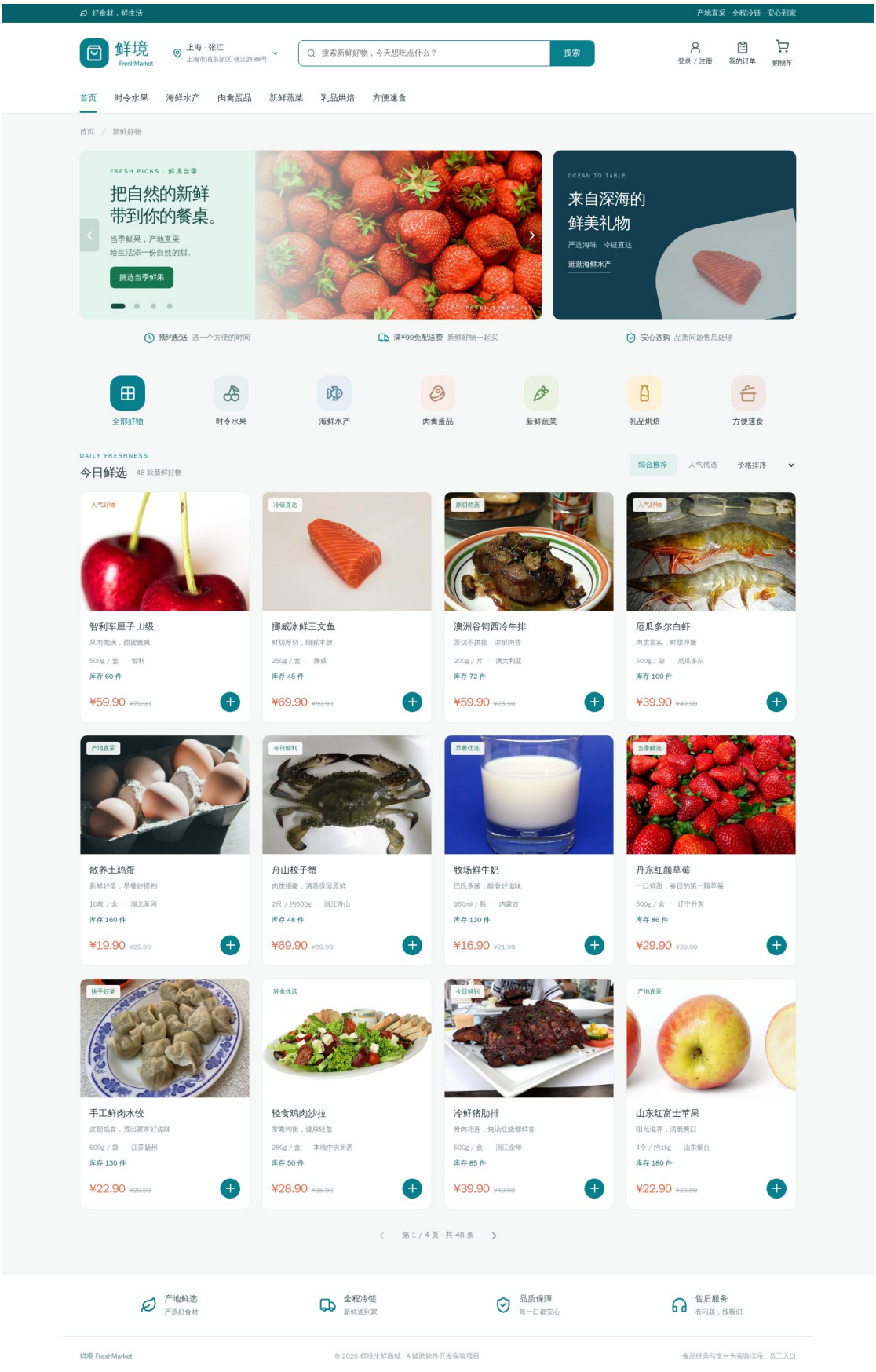


图 1 Docker 部署·桌面商城首页

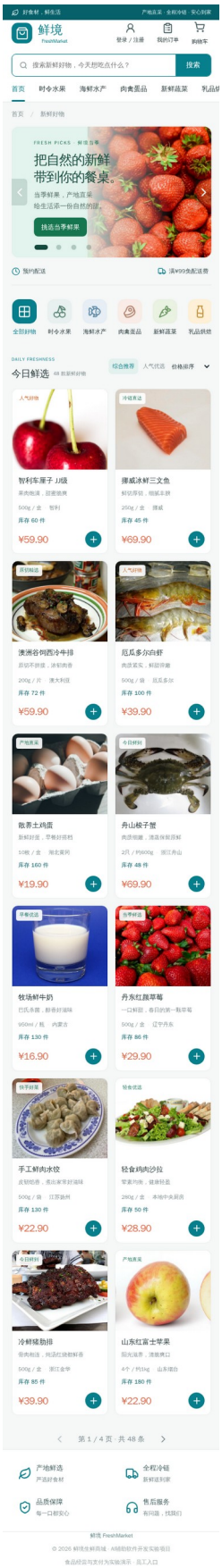


图 2 Docker 部署·手机视口商城

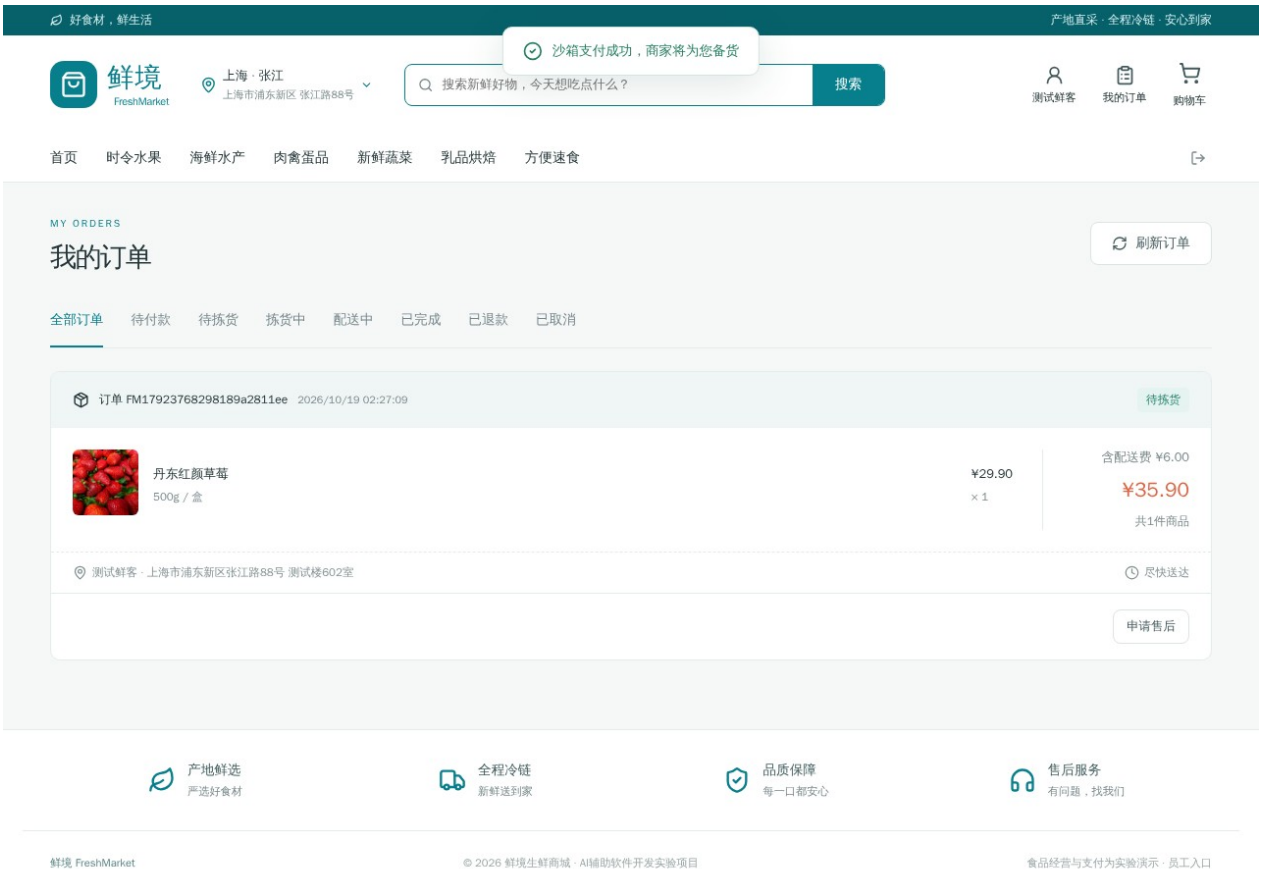


图 3 Docker 部署·会员订单



图 4 Docker 部署·售后工作台

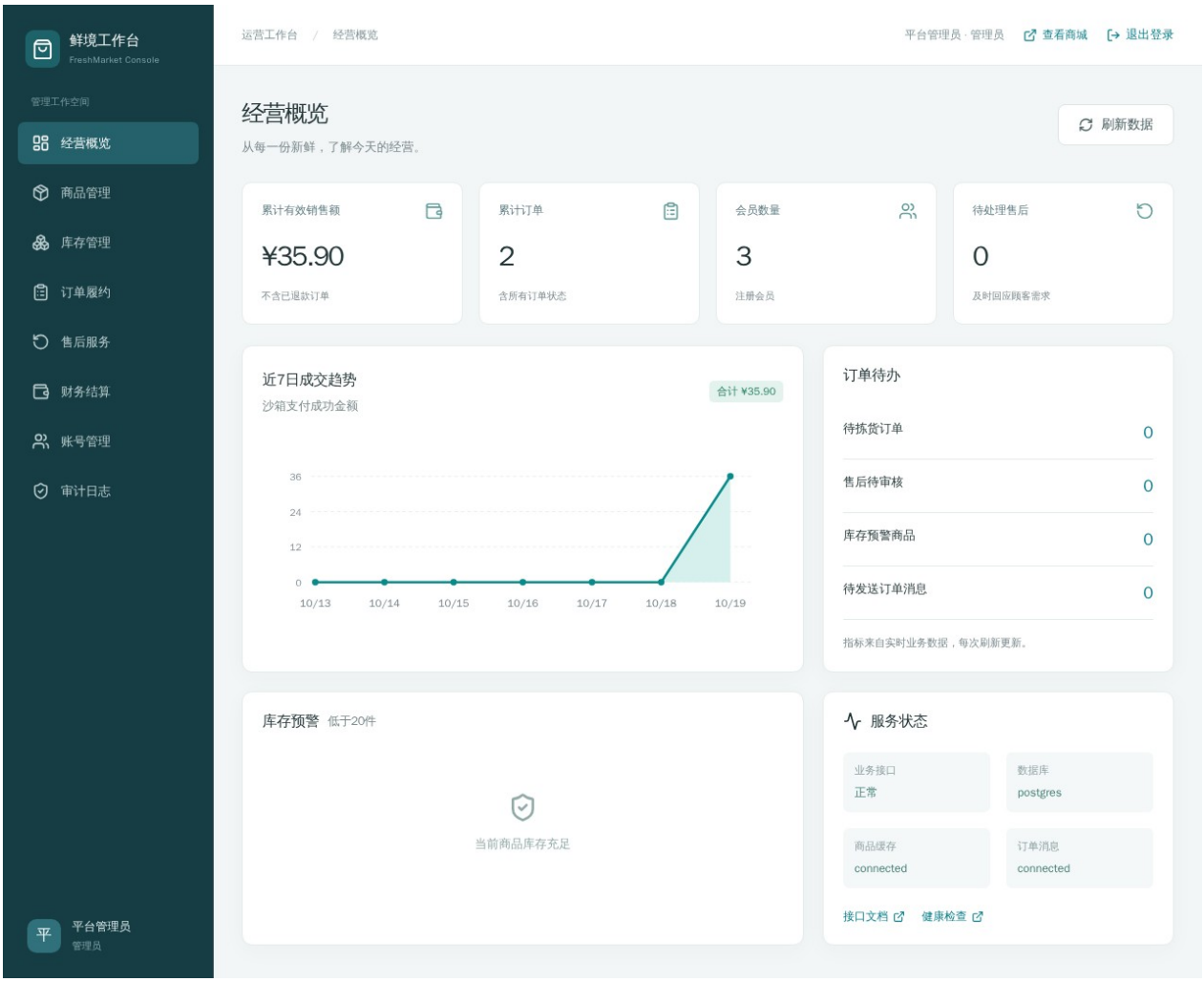


图 5 Docker 部署·经营概览

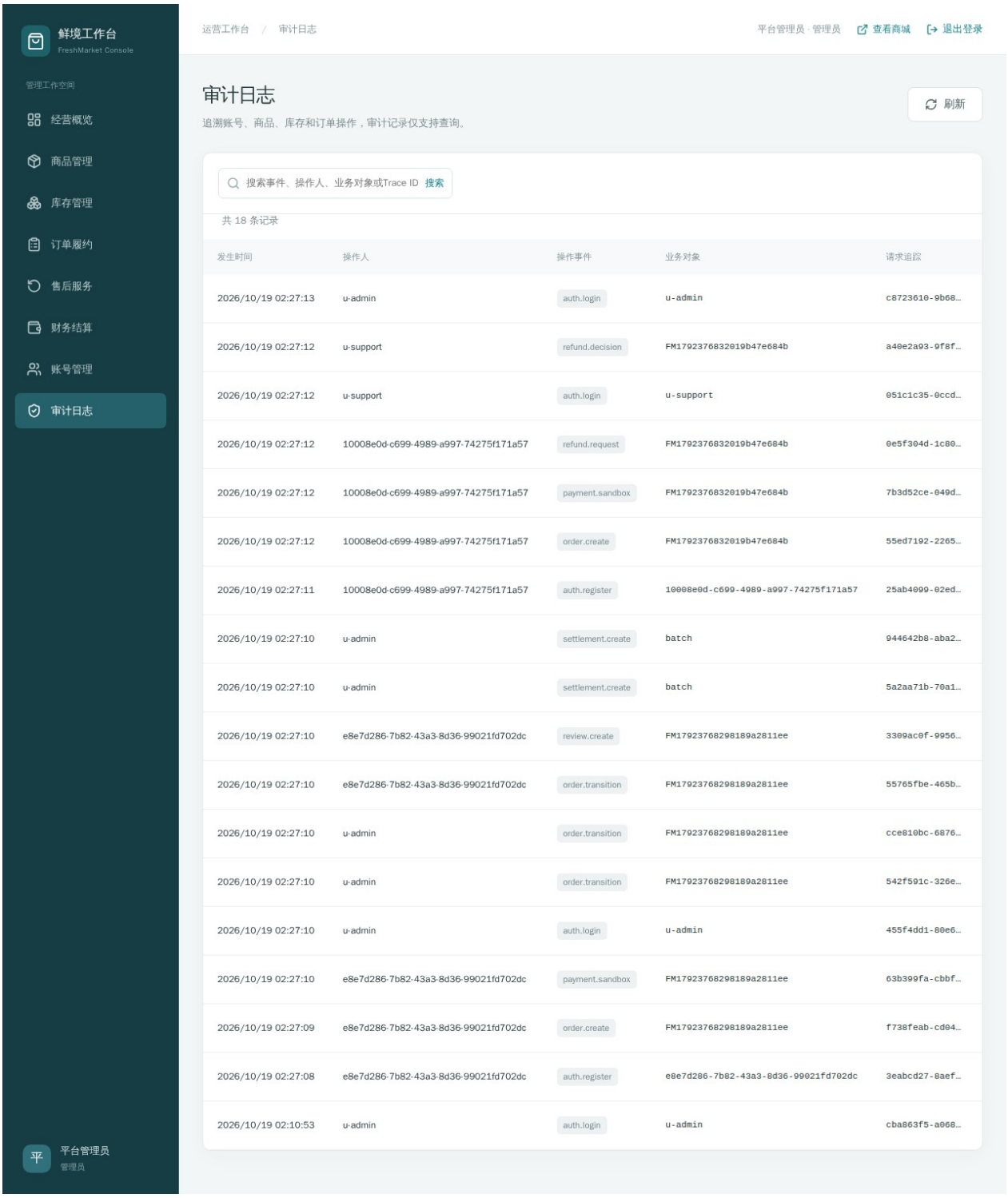


图 6 Docker 部署·审计日志

5.7 运维演练

5.7.1 备份与恢复

步骤	操作	结果
1	记录基线：商品 p01 库存	数据库 86，商品列表 86

步骤	操作	结果
2	执行 pwsh -File scripts/backup.ps1	成功，用时 0.79 s，生成 34,009 字节的 pg_dump 自定义格式文件
3	管理员经 API 调整 p01 库存 +500，模拟备份后的误操作	数据库 586，商品列表 586
4	执行 pwsh -File scripts/restore.ps1 -BackupFile ...	成功，用时 1.81 s：停止 API，单事务 pg_restore，重启 API
5	检查服务	/api/health 在约 2 s 后恢复 200；从开始恢复到服务健康共 2.85 s
6	数据核对	数据库 86，商品详情 86，已回到备份时点
7	缓存核对	恢复后商品列表仍返回 586；31 s 后（超过 30 s TTL）返回 86（DEF-09）
8	残留核对	postgres 容器 /tmp 中遗留 freshmarket.dump 与 restore.dump（DEF-10）

本轮测得恢复耗时 2.85 s，数据集仅为演示规模（转储 34 KB）。这个数字不能作为生产环境的 RTO 承诺。备份为手动触发，没有定时任务，所以 RPO 取决于最近一次手动备份的时间。

5.7.2 回滚

用例	操作	结果
正向	将当前镜像打标签 1.0.0，执行 rollback.ps1 -Version 1.0.0	成功，用时 11.99 s；api 与 web 容器切换为 :1.0.0 镜像，API 健康，网关健康检查 200
反向：版本不存在	rollback.ps1 -Version 9.9.9	按预期失败，提示“Previous API image is not available locally.”，退出码 1，未改动运行中的容器
反向：非法参数	rollback.ps1 -Version 'bad;rm'	按预期被参数校验拒绝，退出码 1

演练中必须手工给镜像打 1.0.0 标签：init-env 生成的 APP_VERSION 固定为 local，每次构建都覆盖同一个标签，默认流程下没有可回滚的旧镜像（DEF-13）。演练结束后已切回 :local 镜像并删除 1.0.0 标签。

5.8 性能测试

测试工具为 scripts/load-test.mjs，请求 GET /api/products?pageSize=12&sort=default，共 200 次，并发 10。

指标	本地 SQLite（直连 API，无 Redis）	Docker 网关（Nginx → API → Redis/PostgreSQL）
测量时间（UTC）	2026-10-19T02:26:42Z	2026-10-19T02:28:30Z
总耗时	0.172 s	0.289 s
QPS	1164.11	691.15
平均响应时间	7.21 ms	13.04 ms
p50	5.46 ms	10.39 ms
p95	17.55 ms	37.58 ms
p99	21.11 ms	83.31 ms
错误数	0	0

两种部署的 p95 都低于 500 ms。在 Docker 网关上紧接着再执行一轮时，200 次请求中 100 次返回 429：前后两轮合计 300 次，恰好用尽 API 全局 300 次/分钟的限额。由于所有请求经同一个 Nginx 出口，限额由全部用户共享（DEF-03）。本测试为短时突发测量，不代表持续负载或生产容量。

5.9 安全测试

编号	测试点	结果
TC-SEC-01	生产模式下使用弱 JWT_SECRET 启动	拒绝启动，CONFIG_INVALID，退出码 1
TC-SEC-02	生产模式下缺少 DATABASE_URL	拒绝启动，退出码 1
TC-SEC-03	生产模式下以默认演示密码开启种子	拒绝启动，退出码 1
TC-SEC-04	网关后限流的客户端隔离	不通过（DEF-03），见下文
TC-SEC-05	生成的 DEMO_PASSWORD 是否暴露	不通过（DEF-02）：值出现在公开的 /assets/index-*.js 中，用它以 admin 登录成功并获得 14 项权限；不出现在镜像 history 中
TC-SEC-06	指标接口外部访问	通过，网关返回 404
TC-SEC-07	数据存储端口暴露	通过，PostgreSQL、Redis 不对宿主机发布
TC-SEC-08	Grafana 匿名访问	通过，返回 401
TC-SEC-09	生产依赖漏洞（npm audit --omit=dev，bb1bde2 锁文件）	通过，0 项
TC-SEC-10	全部依赖漏洞（含开发依赖）	2 项严重：concurrently 9.2.4 依赖的 shell-quote 1.9.0（GHSA-pqg4-j6r4-53mv，CWE-78），已有修复版本（DEF-12）

TC-SEC-04 的复现过程：从宿主机经网关连续发送 12 次错误密码登录，第 1—10 次返回 401，第 11 次由 API 返回 429（RATE_LIMITED），第 12 次由 Nginx 返回 429。随后从 compose 网络内另一

个源地址（API 容器，172.20.0.7）只发送 1 次登录，也立即收到 API 返回的 429 RATE_LIMITED。API 日志中这 12 次请求的 remoteAddress 全部是 Nginx 容器地址 172.20.0.8。结论：API 无法区分真实客户端，登录限额（10 次/分钟）与全局限额（300 次/分钟）由所有用户共享。

6. 缺陷清单

严重级别定义：高——数据错误、安全凭据泄露或阻断发布流水线；中——在部署或运维场景下造成功能不可用或明显风险；低——卫生性问题、可运维性不足或在特定条件下才出现的问题。所有缺陷状态均为“未修复”。

编号	标题	严重级别	模块	验证状态
DEF-01	经营概览在 PostgreSQL 上返回字符串与 NULL，PostgreSQL 测试与 CI 失败	高	后台 API	已确认
DEF-02	演示/管理员密码被构建进公开前端代码，演示开关在 Compose 中写死	高	部署 / 前端	已确认
DEF-03	网关后限流按 Nginx 地址计数，全体用户共享限额	中	网关 / API	已确认（原“待验证”）
DEF-04	容器化测试镜像缺少 web 源码，compose.test.yaml 测试失败	中	部署 / 测试	已确认（原“待验证”）
DEF-05	运维脚本只有 PowerShell 版本，部分脚本依赖 Windows 的 npm.cmd	中	运维脚本	已确认
DEF-06	Compose 项目名写死，同一主机的多套部署共用数据卷	低	部署	已确认
DEF-07	生产网关公开 Swagger UI 与 OpenAPI	低	网关	已确认
DEF-08	API 响应安全头重复且冲突	低	网关 / API	已确认
DEF-09	恢复数据库后商品列表缓存最长 30 s 返回旧数据	低	运维脚本 / 缓存	已确认（原“待验证”）
DEF-10	备份与恢复的转储文件遗留在数据库容器中	低	运维脚本	已确认（原“待验证”）

编号	标题	严重级别	模块	验证状态
DEF-11	PostgreSQL 外键列缺少索引，迁移无并发锁	低	数据库	已确认
DEF-12	开发依赖 shell-quote 存在严重级安全公告	低	依赖	已确认（本轮新增）
DEF-13	默认镜像版本标签固定为 local，没有可回滚的旧镜像	低	部署 / 运维	已确认（本轮新增）
DEF-14	未配置 Alertmanager，告警规则不会发出通知	低	监控	已确认（本轮新增）

DEF-01 经营概览在 PostgreSQL 上返回字符串与 NULL

- 严重级别：高。模块：api/src/modules/admin/controller.ts:20。
- 复现步骤：使用 PostgreSQL（设置 DATABASE_URL 或 TEST_DATABASE_URL），在没有订单时以管理员调用 GET /api/admin/dashboard；或执行 TEST_DATABASE_URL=... npm test。
- 期望结果：orders、revenue、pending_fulfillment、statuses[].count、outbox.pending 均为数值，没有订单时为 0，与 SQLite 一致。
- 实际结果：orders 等为字符串（如 '0'），pending_fulfillment 为 null。TC-API-19 在 system.test.ts:263 失败。GitHub Actions 在 70ca407 与 bb1bde2 两次运行的结论为 failure。（本轮未能取得失败步骤明细，GitHub 匿名接口限流；流水线包含 PostgreSQL 测试步骤，与本地失败现象一致。）
- 影响：接口契约随数据库类型变化，CI 门禁持续失败。当前前端用 Number() 与 || 0 包装，页面显示不受影响。
- 建议：对 totals 各字段做 Number() 转换，SUM 使用 COALESCE(...,0)，statuses 与 outbox 计数同样转换。修复后两种数据库都应通过全部测试。

DEF-02 演示/管理员密码被构建进公开前端代码

- 严重级别：高。模块：compose.yaml（web 构建参数）、web/src/StaffLogin.tsx、web/src/store.tsx。
- 复现步骤：执行 init-env.sh 后启动完整栈；下载首页引用的 /assets/index-*.js，搜索 .env.docker 中 DEMO_PASSWORD 的值；用该值以 admin 调用 /api/admin/auth/login。
- 期望结果：Compose 这种以 NODE_ENV=production 运行的部署中，不应向浏览器下发任何真实凭据；演示入口与演示账号应能通过环境变量关闭。
- 实际结果：密码出现在公开 JS 中（1 处），登录 admin 成功并获得全部 14 项权限。compose.yaml 写死了 VITE_DEMO "true" 与 SEED_DEMO "true"，不修改编排文件就无法关闭。

- 影响：任何能访问网站的人都能拿到管理员权限，API 侧"生产环境强演示密码"的校验因此失去意义。默认只绑定 127.0.0.1 时影响仅限本机；一旦把 WEB_BIND 改为对外地址，即为严重安全事故。
- 建议：VITE_DEMO、SEED_DEMO 改为由环境变量控制并默认关闭；演示密码不注入前端构建，员工演示按钮只填账号不填密码。

DEF-03 网关后限流全体用户共享限额

- 严重级别：中。模块：infra/nginx.conf、api/src/app.ts（Fastify 未启用 trustProxy）、api/src/modules/accounts/controller.ts（登录与注册的路由级限流）。
- 复现步骤：见 5.9 节 TC-SEC-04，或在 1 分钟内经网关发送超过 300 次请求。
- 期望结果：限流按真实客户端计数，一个客户端触发限流不影响其他客户端。
- 实际结果：另一个源地址的第 1 次登录即收到 429；负载测试的第二轮 200 次请求中有 100 次收到 429。
- 影响：Docker 部署下，全站每分钟总计只能完成 10 次会员登录、10 次员工登录、8 次注册与 300 次 API 请求，恶意或正常的高频访问都会使所有用户无法使用。
- 建议：Nginx 传递 X-Forwarded-For 与 X-Real-IP，Fastify 启用 trustProxy 并只信任网关地址；多副本部署时改用共享存储（如 Redis）计数。

DEF-04 容器化测试镜像缺少 web 源码

- 严重级别：中。模块：infra/test.Dockerfile、compose.test.yaml。
- 复现步骤：`docker compose --env-file .env.docker -f compose.yaml -f compose.test.yaml --profile test run --rm tests`。
- 期望结果：容器内测试与宿主机测试一致，全部通过。
- 实际结果：退出码 1，53 个计数中 51 个通过。test/search-highlight.test.ts 报 ERR_MODULE_NOT_FOUND（/app/web/src/search-highlight.js），另 1 项为 DEF-01。
- 影响：官方提供的"部署环境内回归测试"入口不可用。
- 建议：test.Dockerfile 增加 `COPY web ./web`，或把共享的高亮逻辑移到 api 与 web 都能引用的公共位置。

DEF-05 运维脚本只有 PowerShell 版本

- 严重级别：中。模块：scripts/backup.ps1、restore.ps1、rollback.ps1、e2e-docker.ps1、start.ps1。
- 复现步骤：在没有安装 PowerShell 的 Linux 服务器上查找备份/恢复/回滚脚本；检查 e2e-docker.ps1 与 start.ps1 中的 npm.cmd 调用。
- 期望结果：主要的部署目标 Linux 上有原生的备份、恢复、回滚脚本。
- 实际结果：只有 .ps1 版本。本轮在 Linux 上安装 PowerShell 7.6.7 后，backup、restore、rollback 三个脚本可以正常工作；e2e-docker.ps1 与 start.ps1 调用 Windows 专用的 npm.cmd，在 Linux 上无法执行。
- 影响：Linux 运维人员需要额外安装 PowerShell 或手工执行等价命令，增加误操作风险。

- 建议：提供等价的 POSIX sh 脚本，或在文档中把 PowerShell 7 列为运维前置条件，并把 npm.cmd 改为跨平台调用。

DEF-06 Compose 项目名写死

- 严重级别：低。模块：compose.yaml 第 1 行 name: freshmarket。
- 复现步骤：在同一主机上从第二个目录（例如测试副本）执行 compose up。
- 期望结果：不同目录或环境的部署相互隔离。
- 实际结果：两者共用项目名 freshmarket 及其数据卷。若数据卷已由另一套 DB_PASSWORD 初始化，新部署的 API 将无法连接数据库；执行 down -v 还会删除另一套部署的数据。
- 建议：删除写死的项目名，或允许通过 COMPOSE_PROJECT_NAME 覆盖，并在运维说明中强调。

DEF-07 生产网关公开 Swagger UI 与 OpenAPI

- 严重级别：低。模块：api/src/app.ts、infra/nginx.conf。
- 复现步骤：curl http://<网关>/api/docs/、/api/openapi.json。
- 期望结果：生产部署默认不公开接口文档，或要求认证。
- 实际结果：两者均返回 200。
- 建议：生产环境关闭 Swagger UI，或在 Nginx 上像 /api/metrics 一样限制访问。

DEF-08 API 响应安全头重复且冲突

- 严重级别：低。模块：api/src/app.ts（@fastify/helmet）、infra/nginx.conf（add_header … always）。
- 复现步骤：curl -I http://<网关>/api/health。
- 期望结果：每个安全头只有一个明确的取值。
- 实际结果：两条 Content-Security-Policy；X-Frame-Options 同时为 SAMEORIGIN 与 DENY；Referrer-Policy 同时为 no-referrer 与 strict-origin-when-cross-origin；在明文 HTTP 下发送 Strict-Transport-Security。
- 影响：目前浏览器会按更严格的组合生效，没有发现可利用的问题，但策略难以审计和维护。
- 建议：明确由网关或应用其中一方统一设置安全头。

DEF-09 恢复后缓存返回旧数据

- 严重级别：低。模块：scripts/restore.ps1、api/src/core/runtime.ts（Redis 中的目录版本号）。
- 复现步骤：见 5.7.1 节第 3—7 步。
- 期望结果：恢复完成后，所有接口立即返回备份时点的数据。
- 实际结果：数据库与商品详情已是 86，但商品列表仍返回 586，约 30 s 后才恢复正确。
- 建议：恢复脚本在重启 API 前递增 Redis 中的目录版本号，或清空 fresh:catalog:* 键。

DEF-10 转储文件遗留在数据库容器中

- 严重级别：低。模块：scripts/backup.ps1、scripts/restore.ps1。
- 复现步骤：执行一次备份与恢复后，docker compose exec postgres ls -l /tmp。
- 期望结果：容器内不保留数据副本。
- 实际结果：遗留 freshmarket.dump 与 restore.dump（各 34,009 字节）。
- 影响：完整业务数据（含会员手机号、地址）在容器文件系统中多留一份，直到容器重建。
- 建议：复制完成后在容器内删除临时转储文件。

DEF-11 外键列缺少索引，迁移无并发锁

- 严重级别：低。模块：database/schema.sql、api/src/core/database.ts。
- 复现步骤：见 5.3 节 TC-DB-10。
- 实际结果：9 个外键列没有前导索引。其中 addresses.user_id 与 notifications.user_id 位于会员每次访问的查询路径上；删除被引用的行时 PostgreSQL 需要扫描这些子表。migrate() 没有使用 advisory lock，多个 API 副本同时启动时可能发生建表竞争。
- 影响：演示数据规模下没有可感知的影响；数据量增长或多副本部署时成为性能与启动可靠性风险。
- 建议：为高频外键列补充索引，迁移前获取 pg_advisory_lock。

DEF-12 开发依赖严重级安全公告

- 严重级别：低（仅影响开发依赖，生产依赖审计为 0）。
- 复现步骤：在 bb1bde2 锁文件上执行 npm audit。
- 实际结果：concurrently 9.2.4 依赖的 shell-quote 1.9.0 命中 GHSA-pqg4-j6r4-53mv（CWE-78，命令注入），npm 显示已有修复版本。
- 影响：只用于 npm run dev 并行启动前后端，不进入生产镜像；但开发者机器与 CI 环境仍会安装该版本。
- 建议：升级 concurrently/shell-quote 至修复版本并重新锁定依赖。

DEF-13 默认镜像标签固定，没有可回滚的旧镜像

- 严重级别：低。模块：scripts/init-env.sh、scripts/init-env.ps1（APP_VERSION=local）、compose.yaml、scripts/rollback.ps1。
- 复现步骤：按默认 .env.docker 多次执行 up -d --build，然后执行 rollback.ps1 指定任何旧版本。
- 期望结果：每次发布生成可追溯的版本标签，可以回滚到上一版本。
- 实际结果：每次构建都覆盖 freshmarket-api:local 与 freshmarket-web:local，本地不存在其他版本。本轮演练需要手工打标签才能执行回滚。
- 建议：发布流程强制设置 APP_VERSION（如使用 git 短哈希），并保留最近 N 个版本的镜像。

DEF-14 告警没有接收端

- 严重级别：低。模块：infra/prometheus.yml、compose.yaml。

- 复现步骤：查询 Prometheus /api/v1/alertmanagers。
- 实际结果：activeAlertmanagers 为空。3 条告警规则正常评估，但触发后不会通知任何人。
- 建议：部署 Alertmanager 并配置值班通知渠道，或在 Grafana 中配置告警联系点。

7. 覆盖率与未覆盖风险

7.1 需求覆盖

需求类别	覆盖的测试	覆盖情况
FR-ACC 会员账号与认证	TC-API-04—06、08、09、11、51、55；TC-E2E-04	已覆盖
FR-CAT 商品目录/搜索/推荐/详情	TC-API-01—03、21—30；TC-E2E-01、02	已覆盖
FR-CART 购物车	TC-API-31；TC-E2E-04	已覆盖
FR-ADDR 收货地址与配送区域	TC-API-53；TC-E2E-07	已覆盖
FR-ORD 下单/支付/取消/超时/收货	TC-API-32—43；TC-E2E-04、08	已覆盖
FR-AFS 售后退款	TC-API-44—47；TC-E2E-05、09	已覆盖
FR-REV 评价	TC-API-48；TC-E2E-04	已覆盖
FR-NTF 消息通知	TC-API-50；中间件冒烟第 5—8 项	已覆盖
FR-ADM-DASH 经营概览	TC-API-19、54；TC-E2E-05	已覆盖，PostgreSQL 上不通过（DEF-01）
FR-ADM-PRD 商品管理	TC-API-17、18、29	已覆盖
FR-ADM-STK 库存	TC-API-52；TC-E2E-06；中间件冒烟第 3 项	已覆盖
FR-ADM-ORD 订单履约与维护	TC-API-19、20、43；TC-E2E-04	已覆盖
FR-ADM-AFS 售后审核	TC-API-44；TC-E2E-05	已覆盖
FR-ADM-SET 财务结算	TC-API-47、49；TC-E2E-04	已覆盖
FR-ADM-USR 账号管理	TC-API-07、10、12—16	已覆盖
FR-ADM-AUD 审计	TC-API-52；TC-E2E-05	已覆盖
FR-OPS 运维接口	TC-API-54；TC-DEP-05—07	已覆盖
NFR-PERF 性能	5.8 节	部分覆盖：只做短时突发测量
NFR-REL 一致性/可靠性	TC-API-34—41、50；中间件冒烟；恢复演练	已覆盖
NFR-AVL 可用性/降级	健康检查、启动顺序	部分覆盖：没有做 Redis/RabbitMQ 宕机注入
NFR-SEC 安全	5.9 节	已覆盖，存在 DEF-02、DEF-03、DEF-07、DEF-08
NFR-PRIV 隐私	TC-API-54（员工订单手机号脱敏）	部分覆盖，存在 DEF-10

需求类别	覆盖的测试	覆盖情况
NFR-OBS 可观测性	5.5 节监控检查	已覆盖，存在 DEF-14
NFR-DEP 部署/运维	5.4、5.7 节	已覆盖，存在 DEF-04、05、06、09、13
NFR-MNT 可维护性	类型检查、覆盖率	已覆盖
NFR-CMP 兼容性	TC-E2E-03	部分覆盖：只测了 Chromium

7.2 未覆盖风险

- 故障注入：没有在运行中停止 Redis 或 RabbitMQ 来验证降级与 Outbox 积压后的补发；本轮只验证了组件正常时的链路。
- 长时间运行：没有验证 15 分钟支付超时在真实时间下的触发（自动化测试通过模拟时间覆盖），也没有观察内存与连接池的长期行为。
- 规模：所有测试都基于演示数据规模（48 个商品、少量订单），无法推断大数据量下的搜索（应用层模糊匹配）与后台 LIKE 查询性能。
- 浏览器：没有覆盖 Firefox、Safari/WebKit 与真机。
- 平台：PowerShell 脚本没有在 Windows 上执行；Windows 本地 start.ps1 启动路径未测试。
- 安全：没有进行渗透测试、容器镜像漏洞扫描与 HTTPS 部署验证（当前编排只提供 HTTP）。

8. 结论与发布建议

8.1 准出准则核对

准出准则	结果
所有自动化用例在两种数据库上全部通过	未满足：PostgreSQL 54/55，容器化测试 51/53
不存在未关闭的高级缺陷	未满足：DEF-01、DEF-02 未修复
部署与运维演练全部成功，恢复后数据与备份时点一致	满足（数据库层面）；缓存短暂不一致见 DEF-09
生产依赖无已知高危或严重漏洞	满足

8.2 结论

系统的核心业务逻辑质量较高：并发防超卖、幂等下单、支付与取消竞争、售后与结算互斥、会话失效等关键一致性场景，在两种数据库上全部通过；真实中间件链路、端到端流程与运维演练也全部成功。不能发布的原因集中在部署配置与跨数据库契约：一处接口在 PostgreSQL 上类型错误导致 CI 失败；Compose 部署把管理员密码下发到浏览器；网关后的限流把所有用户合并成同一个客户端。

8.3 发布建议

- 本机隔离的教学演示：有条件通过，前提是保持 WEB_BIND=127.0.0.1，且不把 .env.docker 中的演示密码用于其他系统。
- 任何对外部署（局域网、公网、预发布）：不建议发布。必须先修复 DEF-01、DEF-02、DEF-03、DEF-04，并在修复后重新执行第 4 章全部测试项（R01—R23）。
- DEF-05 至 DEF-14 建议在下一个迭代修复。其中 DEF-09、DEF-10、DEF-13 涉及数据恢复与回滚能力，应在正式上线前完成。

附录 A 复现命令

以下命令在仓库根目录执行，Node.js 版本须为 24 或以上。

```
npm ci
npm run typecheck
npm test
TEST_DATABASE_URL=postgres://test:test@127.0.0.1:55432/freshmarket_test npm test
npm run build
npm audit --omit=dev
```

完整栈与容器化测试：

```
sh scripts/init-env.sh
docker compose --env-file .env.docker config --quiet
docker compose --env-file .env.docker up -d --build
docker compose --env-file .env.docker -f compose.yaml -f compose.test.yaml --profile test run --rm tests
docker compose --env-file .env.docker cp scripts/infra-smoke.mjs api:/app/infra-smoke.mjs
docker compose --env-file .env.docker exec -T api node infra-smoke.mjs
```

端到端测试（官方 Playwright 镜像，本地模式需先执行 npm run dev）：

```
docker run --rm --network host --ipc=host -v "$PWD":/work -w /work \
 -e E2E_BASE_URL=http://127.0.0.1:5173 -e E2E_SCREENSHOT_DIR=docs/screenshots/2026-10-18/local \
 mcr.microsoft.com/playwright:v1.63.0-noble npx playwright test --reporter=list,json
```

运维演练（PowerShell 7）：

```
pwsh -File scripts/backup.ps1
pwsh -File scripts/restore.ps1 -BackupFile backups/freshmarket-YYYYMMDD-HHMMSS.dump
pwsh -File scripts/rollback.ps1 -Version 1.0.0
```

性能测试：

```
LOAD_BASE_URL=http://127.0.0.1:3001 node scripts/load-test.mjs
```

附录 B 证据文件索引

所有文件位于 docs/evidence/2026-10-18/，密钥已替换为占位符（如 <DEMO_PASSWORD>）。

文件	内容
environment-versions.txt	运行时、数据库、中间件、框架的精确版本
typecheck.txt、build.txt	类型检查与生产构建输出
api-tests-sqlite.txt、api-tests-postgres.txt	两种数据库上的 API 测试完整输出与覆盖率

文件	内容
def04-compose-test-run.txt	compose.test.yaml 容器化测试输出
db-schema-seed-load.txt	SQL 脚本在 PostgreSQL 与 SQLite 上的加载与幂等检查
db-upgrade-seed-checks.txt	旧版本升级、种子一致性、用户名复用检查
db-fk-index-check.txt	外键列索引检查
docker-compose-up.log	完整栈构建与启动日志
docker-gateway-checks.txt	网关、端口、响应头、运行用户检查
docker-demo-password-exposure.txt	演示密码暴露检查（已脱敏）
def03-rate-limit-shared-bucket.txt	网关后限流共享复现
infra-smoke.json	中间件集成冒烟结果
monitoring-and-mq-checks.txt	Prometheus、Grafana、RabbitMQ 检查
prod-config-validation.txt	生产配置守卫测试
e2e-local-list.txt、e2e-local-results.json、e2e-local-devserver.log	本地端到端测试
e2e-docker-list.txt、e2e-docker-results.json	Docker 端到端测试
ops-backup-restore-drill.txt、ops-rollback-drill.txt	运维演练记录
load-local-sqlite.json、load-docker-gateway.json、load-docker-gateway-run2.json（及同名 .log）	性能测试原始数据
npm-audit-full.json、npm-audit-prod.json	依赖漏洞审计（bb1bde2 锁文件）
github-actions-runs.json	GitHub Actions 最近 10 次运行记录
teardown.txt	测试环境清理记录

截图位于 docs/screenshots/2026-10-18/local/ 与 docs/screenshots/2026-10-18/docker/。

2026年10月20日修订补充

本补充适用于 725696a 基线及 2026-10-20 工作区修复。前文 2026-10-18 / bb1bde2 的正文、图表、历史测试和原有格式完整保留；涉及本轮变更的当前状态以本补充为准。未重新执行的验收不沿用旧结果，也不改写历史事实。

补充测试对象和环境

本补充记录 git pull 后的 725696a 及本轮工作区修复。前文 bb1bde2 的 54/55、51/53、CI 失败、缺陷状态和发布建议仍是当时的事实，不能解释为本轮结果。本轮没有执行远端 CI，也不把本地通过等同于托管流水线成功。

系统 Node v24.12.0、npm 11.20.0；项目 node 依赖使 npm scripts 实际使用 Node v26.12.0。API 集成回归使用内存 SQLite，浏览器使用持久化 SQLite 开发服务和 Edge。默认 5173 被既有 VS Code 进程占用且不响应，改用本轮 Vite 的 5174 后通过；没有终止占用端口的原进程。

本轮结果与覆盖范围

npm run typecheck、npm run build：通过，原始输出为 typecheck.txt 和 build.txt。npm test：84/84 通过，0 失败，约 14.28 秒。行/分支/函数覆盖率分别为 96.54% / 88.39% / 91.91%；包含导入的前端搜索高亮模块，不代表前端整体覆盖率。

Edge Playwright：9/9 通过，29.3 秒，无跳过、失败或 flaky。覆盖桌面/手机商城、分类高亮、下单至结算、售后、仓库权限、地址选择、配送时段及弹窗输入。截图位于 docs/screenshots/2026-10-20/local/。未新增优惠券或秒杀的浏览器用例。

PowerShell 恢复控制流：5/5 通过，分别模拟 stop、pg_restore、FLUSHDB、start 失败及全部成功；docker 为函数替身，没有操作真实容器。Compose 静态配置验证不同项目名生成不同 PostgreSQL 数据卷名，没有启动部署。

全量 npm audit（含开发依赖）：已知漏洞总数 0。锁文件使用 concurrently 9.2.5 / shell-quote 1.12.0；本轮未强制升级依赖。YAML/JSON 解析检查通过，但不能替代 promtool 和真实告警验收。

新增故障回归

runtime.test.ts 新增八项：通道单独关闭后的重建和旧事件隔离；拓扑初始化失败清理与重试；通道错误和消费者取消后的恢复；不可路由 return 后即使正向 confirm 仍待重试；批次断连不切换进程内消费；负向确认与同步发布异常；五秒确认超时；数据库故障、已配置依赖中断及恢复时的指标变化。

指标回归同时确认：数据库不可用时 /api/health 为 500，而 /api/metrics 仍可成功返回并把数据库指标置零；积压查询失败输出非数值，不延用旧正常值。Redis/MQ 指标仅代表连接就绪。首次新增指标断言误匹配 HELP 行和非数值大小写，修正断言后全部通过。

原缺陷清单的当前状态

DEF-01：代码修复且 SQLite 回归通过，PostgreSQL 本轮未重跑。DEF-02：已移除公开部署密码的构建路径，前端生产构建只填账号；真实部署密码暴露检查未复验，教学开关默认仍开，对外部署须关闭并处理现有演示账号。

DEF-03：代理地址覆盖和可信跳数已实现，注入回归通过；限流仍为单实例内存计数。DEF-04：镜像已复制 web，真实镜像构建和运行待复验。DEF-05：已有 POSIX 运维脚本，本轮未在 Linux 演练。

DEF-06：移除固定项目名，两套静态卷名隔离验证通过。DEF-07、08：网关文档阻断和重复头隐藏已配置，真实响应本轮未复验。DEF-09：恢复后清专用缓存；失败控制流通过，真实恢复待复验。DEF-10：临时转储已尽力清理，Docker 故障时仍须人工检查残留。

DEF-11：索引与 PostgreSQL 迁移锁已实现，SQLite 迁移通过，PG 并发迁移未重跑。DEF-12：本轮全量审计为 0。DEF-13：已有唯一版本部署脚本与历史，真实回滚未演练，直接覆盖 local 标签仍不保证可回滚。DEF-14：部分完成，Alertmanager 路由已实现，外部邮件/Webhook 接收器仍未配置。

旧设计观察 OBS-01、OBS-02、OBS-06 已有修复及自动回归；OBS-03 推荐权重归一化、OBS-04 重试退避/上限和 OBS-05 查询分层仍未完成。新增 MQ、恢复失败检查、监控和项目隔离修复的当前实现详见同名设计文档修订补充。

发布边界与证据

本轮结果支持本地教学环境的代码回归结论，不构成生产发布验收。Docker Linux 引擎未运行，PostgreSQL、真实 Redis/RabbitMQ 故障、容器化测试、网关响应、Prometheus 告警触发/恢复、Linux 运维、真实备份恢复及版本切换均未执行。外部告警交付仍待配置验证。

原始输出统一保存在 docs/evidence/2026-10-20/：api-tests-sqlite.txt、e2e-local.txt、e2e-results.json、restore-control-flow.txt、compose-isolation.json、typecheck.txt、build.txt、npm-audit-full.json 和 config-validation.txt。旧 2026-10-18 证据未覆盖。详细当前状态见 docs/maintenance-2026-10-20.md。